

PHISHING DETECTION SYSTEM

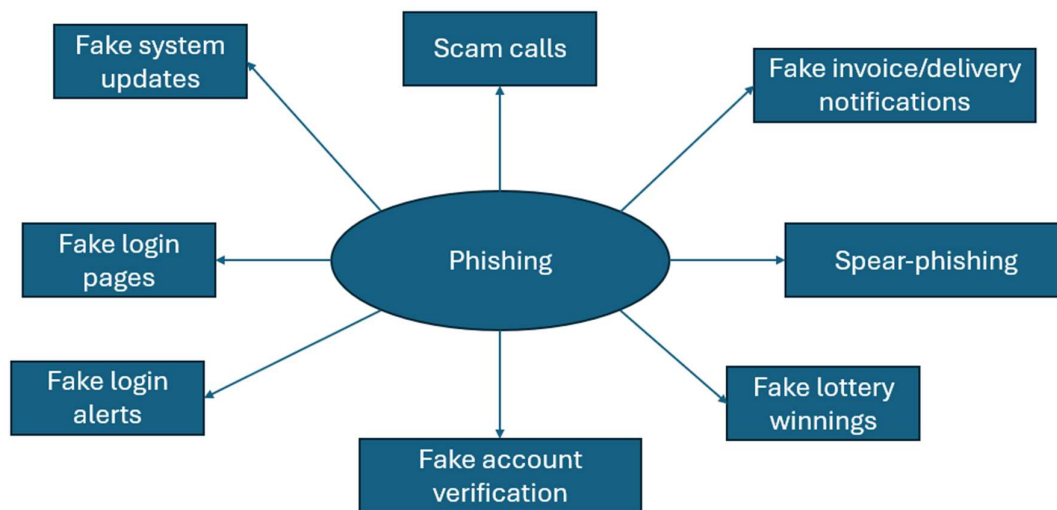
Contents

Introduction	2
Main phishing detection system	3
Vishing Detection Example	4
Technical controls against phishing	5
Phishing Detection System Trade-Offs	6

Introduction

This phishing detection system is designed to aid users in detecting and preventing successful phishing attempts. This system is built on technical, behavioural and human layers. This phishing detection system was developed as phishing is one of the biggest attack vectors used by all current threat actors in Cybersecurity. For those who may not what phishing is, phishing is the act of tricking someone into giving information or downloading something without realising it. phishing is effective because it targets the user instead of the technical controls. This is a common vector for attackers because humans can be stressed, panicked, scared and tricked easily sometimes. Some common types of phishing currently used as fake system updates, fake login pages and fake login alerts.

While this system cannot completely prevent phishing, it can reduce the chance of success heavily. This system may not be as effective in detecting or preventing spear-phishing. This is because spear-phishing uses personalised details to trick a specific target into providing credentials or downloading malware. However, this system may be effective against most other types of phishing due its behavioural analysis of phishing, technical controls used to catch human error and the human layer making the final decision with my security architecture's decision framework. This system should not be blindly trusted as the only way to reduce the chances of phishing. Make sure to adapt this system based on your own security needs and threat model.



The spider diagram shows the common phishing tactics used by attackers in 2026. While spear-phishing is usually used by threat actors such as organised cybercriminals or nation-state/APT, it is important to be aware of as an attacker may be able to use a spear-phishing attack if they were to gain enough information about their target.

Main phishing detection system

- The first step of this phishing detection system is to calm down
- This can be done by taking a few deep breaths
- The second step is to identify what the fake login alert is about
- For example, the email could be from Spotify or from your bank
- If the email is from a service, you don't use then it is suspicious by default
- The third step is verification
- This is where you would check the email for the signs of phishing
- This step can be directly supported by the usage of security training
- Sometimes an attacker can use AI-generated phishing emails to trick you
- If the grammar seems too perfect, you may check against 1 or 2 AI detectors for AI usage
- Do not only rely on the step above for detecting fake login alerts
- The fourth step is cross-referencing
- This is where you would cross-reference against real login alerts from the past
- These real login alerts should be stored securely but remain accessible for quick and effective usage.
- They should not be stored in your email as an attacker can compromise that more easily.
- There is one rule that should be followed even if the email has bypassed all verification steps
- This rule is to never click on the link and verify through the actual website by manually typing in the domain
- The final step is to document the attempt
- This can use the structure What (What was the phishing technique) → Why (What was the goal behind it?) → How (How did you detect it?) → Potential improvements (What could be improved for next time?)
- There is also an extra step below that organisations may set up for further protection and detection against phishing.
- A company can setup an ML model which uses behavioural and signature-based detection
- The company can use their own logs and login alerts for the training data of the model
- They can also train the ML model to recognise the signs of phishing
- This ML model should block for high probability cases but flag to the user for low probability cases. It is important to note that they may be false positives.

Vishing Detection Example

- The first step is to calm down.
- This is where you reduce the emotional noise of the situation as this situation or other events during the day can cause stress and frustration.
- This can be done by taking deep breathes or releasing anger in a non-harmful way.
- The second step is identifying.
- This is where you figure out what the call is about.
- This can be done by asking yourself questions like what is the call about? Who is calling me? Why are they calling me?
- The third step is verification
- This is where you check the call for signs of vishing to spot out the most obvious attempts.
- This can be done by recognising that vishing usually asks for something to gain access to your account or another system you work with.
- For example, attackers can commonly ask for social security numbers, verifying a code or even for remote access to your device.
- The fourth step is cross-referencing.
- This is where you check against what you know and usually call activity on your phone.
- This can be done by asking yourself if you usually get called by a service, a specific person and how the person usually behaves.
- This step is important as it can catch an attacker from mimicking someone you know as they cannot mimic their behaviour perfectly.
- If you can't remember all the steps, then there is one hard rule you can follow to ensure that vishing isn't as effective.
- This hard rule is to always verify through the official number and tell the caller you will do so.
- If the caller is authentic, they will agree and not try stop you from calling the official number, but this doesn't mean they are to be trusted.
- If the caller is an attacker, they will not agree and try stop you from calling the official number.
- The fifth and final step is documentation.
- This is where you document the vishing attempt and learn from any mistakes you may have made
- This can use the structure What (What was the phishing technique) → Why (What was the goal behind it?) → How (How did you detect it?) → Potential improvements (What could be improved for next time?)

Technical controls against phishing

- These technical controls were made as an SafetyNet against human error as it can start.
- This is because humans can still make mistakes as it is part of their nature.
- There are 6 protections that can be implemented against phishing
- The first protection is strong unique 12-16 characters passwords for each account
- These passwords should be stored securely in a password manager
- This protects against phishing because it prevents an attacker from using one set of compromised credentials to compromise multiple accounts.
- The second protection is MFA which stands for multi factor authentication
- MFA should be through authentication apps or hardware keys
- Try avoiding SMS or Email-based MFA when possible
- Hardware keys are phishing resistant
- This protects against phishing because it prevents unauthorized access to your account even if an attacker has compromised your password.
- The third protection is OPSEC which stands for operational security
- You should limit the information that is publicly available on social media and other sources
- This is because social media is the most common source of information gathering which allows an attacker to perform spear-phishing attacks
- This protects against phishing because an attacker can't use spear-phishing or most other types of phishing if they don't have information on you
- The fourth protection is email separation
- This is where you would limit permissions of others in your systems
- For example, you may not use the same email for recovery for all your accounts
- This could mean using a separate and isolated account as recovery for your bank account.
- The fifth protection is security training
- Security training is where you simulate phishing attempts and train yourself to identify the signs of what phishing looks like.
- Security training can include simulating phishing emails and fake login pages.
- Security training protects against phishing as it allows you to spot the most obvious attempts that most people will see in their lifetime.
- The sixth protection is anti-virus software.
- While anti-virus software doesn't directly protect against phishing it can still prevent the aftermath of it.
- This is because phishing may allow attackers to install malware on your device which anti-virus can stop.
- For example, you could use Windows Defender, Bitdefender, Malwarebytes and other options depending on your operating system and budget.

Phishing Detection System Trade-Offs

- **This phishing detection system has trade-offs just like any other system I have built so far.**
- **There may also be further implementation issues depending on the type of social engineering tactic used.**
- **I have identified 4 main trade-offs with this phishing detection system.**
- **The first trade-off is cost.**
- **This trade-off exists because security training courses, AV and ML models for organizations can be expensive and time-consuming to gain.**
- **This means that most users won't be able to afford the best security options especially with ML or AV with the best current detection rates.**
- **This trade-off can be managed by allocating security budget, threat modelling to focus protections and using built in/free tools where possible.**
- **The second trade-off is maintenance.**
- **This trade-off exists as the technical controls can require you to train to detect the latest phishing techniques and maintain OPSEC throughout your digital life.**
- **This trade-off can be managed by doing security training based on available times in your schedule and only maintaining OPSEC where its needed (Social media).**
- **The third trade-off is spear-phishing.**
- **This trade-off exists as this phishing detection system cannot detect spear-phishing as effectively compared to other tactics.**
- **This means that attackers who use spear-phishing may have higher success rates compared to using other tactics like vishing or phishing in general.**
- **This trade-off can be managed by using OPSEC to reduce information and following the hard rule which allows you to avoid clicking on the link.**
- **The fourth trade-off is cognitive load.**
- **This trade-off exists as checking every email or call you get using this phishing detection system can be exhausting.**
- **This means that users will skip the steps if they use up too much energy and time as people can get dozens of emails per day.**
- **This trade-off can be managed by remembering the hard rule if not anything else, using the system to check suspicious emails or calls and threat modelling to know where an attacker is mostly going to attack you.**